Diplomatura en Ciberseguridad

Título:
Trabajo Práctico – Módulo 5: La inteligencia en la Ciberseguridad

Análisis de Brechas de Seguridad de la Información en SmartCity Córdoba

Estudiante:
Lucas Caminos

Fecha:
5 de octubre de 2025

Introducción

Este informe presenta un análisis de brechas de seguridad (Gap Analysis) en SmartCity Córdoba, organización ficticia dedicada a la gestión digital de servicios públicos.
Se busca identificar diferencias entre el estado actual de la seguridad y los estándares ISO/IEC 27001:2022 y NIST CSF v1.1, priorizando brechas críticas en procesos como datos ciudadanos, infraestructura IoT y servicios en la nube.
El fin es proponer acciones que eleven la madurez y resiliencia institucional frente a amenazas digitales.

Desarrollo

Metodología aplicada

Se aplicó un enfoque PDCA (Plan–Do–Check–Act) complementado con ISO 27001 y NIST CSF.
El proceso incluyó: relevamiento del estado actual, comparación con los controles de referencia, identificación de brechas (Cumplido/Parcial/No Cumplido), evaluación cualitativa del riesgo (impacto × probabilidad) y propuesta de mejoras priorizadas por horizonte de tiempo.

Procesos críticos de negocio

Proceso	Activos principales	Riesgos identificados
Gestión de datos ciudadanos	Bases de datos con información personal y sanitaria	Acceso indebido, fuga de datos, manipulación de registros
Plataforma IoT urbana	Sensores de tránsito, alumbrado y residuos conectados a red	Secuestro de dispositivos, ataques DDoS, manipulación de señales
Centro de operaciones (SOC)	Servidores de monitoreo y registro de eventos	Falta de correlación de alertas, ausencia de turnos 24×7
Continuidad de servicios	Copias de seguridad, servidores cloud, DRP	Falta de pruebas periódicas y de mecanismos de failover

Marco de referencia y resultados del análisis

Se utilizaron como referencia los controles de ISO 27001 y las funciones del NIST CSF (Identify, Protect, Detect, Respond y Recover). El siguiente cuadro resume los principales hallazgos y brechas detectadas.

Dominio de control	Situación actual	Estado deseado	Nivel de riesgo	Recomendación
Gobierno de la seguridad (ISO A.6)	Roles definidos parcialmente, sin CISO formal	Comité de seguridad y responsable designado	Alto	Crear estructura formal de gobierno y reportes a la dirección
Control de accesos (ISO A.9)	Accesos manuales, sin autenticación multifactor	Autenticación fuerte y revisiones periódicas	Alto	Implementar MFA y auditorías trimestrales de privilegios
Seguridad operacional (ISO A.12)	Copias locales sin verificación	Backups en nube y comprobación automática	Medio	Automatizar copias y validar restauraciones
Seguridad de comunicaciones (ISO A.13)	Segmentación básica en red IoT	Microsegmentación y cifrado TLS	Alto	Separar redes IoT y cifrar tráfico interno
Gestión de incidentes (ISO A.16)	No existen procedimientos documentados	Playbooks y sistema de registro centralizado	Alto	Definir procesos de respuesta y capacitar al personal
Continuidad del negocio (ISO A.17)	Plan sin pruebas desde 2022	Pruebas regulares y actualización anual	Medio	Realizar simulacros y revisar plan de recuperación

Las brechas más críticas corresponden a la falta de gobierno de seguridad, la gestión de incidentes y la protección de la red IoT, donde la exposición es alta.

Plan de acción propuesto

Para elevar el nivel de madurez y reducir los riesgos detectados, se propone un plan escalonado en tres fases:

1. **Corto plazo (0 – 6 meses):**
   • Crear el Comité de Seguridad y designar un CISO dependiente de la Dirección de Tecnología.
   • Emitir políticas generales de seguridad y comunicarlas a todo el personal.
   • Implementar autenticación multifactor (MFA) en sistemas administrativos.
   • Auditar cuentas y privilegios para eliminar accesos innecesarios.

2. **Mediano plazo (6 – 12 meses):**
   - Automatizar respaldos en nube híbrida con verificación de restauración.
   - Documentar y probar los procedimientos de respuesta a incidentes.
   - Centralizar registros y alertas (SIEM) para reducir tiempos de detección.
   - Ensayar periódicamente el plan de continuidad y contingencia.
3. **Largo plazo (12 – 24 meses):**
   - Segmentar y cifrar la red IoT.
   - Evaluar la adopción de una plataforma SOAR.
   - Integrar indicadores de seguridad al tablero municipal.
   - Mantener un programa continuo de concientización.

El avance se medirá mediante indicadores como el tiempo medio de detección y respuesta (MTTD/MTTR), el cumplimiento de controles ISO 27001, el porcentaje de usuarios con MFA activo y la disponibilidad de servicios digitales.

Indicadores generales

Se proponen métricas de seguimiento técnico y organizacional:

- **Cumplimiento de controles ISO 27001 ≥ 85 %.**
- **Disponibilidad de servicios ≥ 99,5 %.**
- **Reducción anual de incidentes críticos.**

La implementación integral del plan permitiría evolucionar del **Tier 1 (Partial)** al **Tier 3 (Risk-Informed)** del marco NIST en un plazo estimado de 24 meses.

Conclusiones

El análisis de brechas realizado permitió identificar ocho desviaciones principales respecto de los marcos ISO/IEC 27001:2022 y NIST CSF v1.1, de las cuales tres fueron clasificadas como críticas, tres como altas y dos como medias.
Las áreas de mayor vulnerabilidad se concentran en el gobierno de la seguridad, la gestión de incidentes y la protección de redes IoT, reflejando la falta de roles definidos, políticas formales y segmentación adecuada de la infraestructura.

La comparación con los marcos internacionales evidencia que SmartCity Córdoba se encuentra en un nivel inicial de madurez, con controles implementados parcialmente y sin mecanismos de medición continua.
No obstante, el plan propuesto establece un camino claro de evolución hacia un modelo de seguridad gestionada y proactiva, donde las decisiones se fundamentan en indicadores verificables y mejora continua.

La ejecución gradual de las acciones —como la creación del Comité de Seguridad, la incorporación de MFA, la adopción de SOAR y la capacitación sostenida del personal— permitirá que la organización transite del Tier 1 al Tier 3 del NIST CSF, consolidando un marco de ciberresiliencia alineado con las mejores prácticas globales.
Además, la adopción de métricas y auditorías regulares favorecerá la transparencia y la rendición de cuentas, fortaleciendo la confianza tanto interna como ciudadana.

En síntesis, la ciberseguridad en el ámbito municipal debe asumirse no como un requerimiento técnico, sino como una política estratégica esencial para garantizar la continuidad operativa, la protección de los datos ciudadanos y la legitimidad de los servicios públicos digitales.